

Mise en place et vérification des habilitations

Objectif

Garantir que les accès aux différentes fonctionnalités du site Blog sont sécurisés et réservés aux utilisateurs autorisés, selon leur rôle (utilisateur standard ou administrateur).

1. Définition des rôles et permissions

Rôle	Permissions principales
Utilisateur	- Créer un compte - Se connecter - Publier un article - Évaluer un article - Accéder au panneau d'administration - Modifier / Supprimer des projets ou articles
Administrateur	- Gérer les avis - Modérer les suggestions

2. Mise en place des habilitations

a. À l'inscription

Le rôle par défaut est "Utilisateur".

Les informations sont stockées dans la base de données avec un champ `role` ('user' ou 'admin').

b. À la connexion

Une session est ouverte avec les identifiants et le rôle de l'utilisateur.

Des vérifications sont faites à chaque chargement de page restreinte.

c. Interface administrateur

L'accès aux pages de gestion (ajout, modification, suppression) est restreint au rôle admin.

Les boutons d'action n'apparaissent pas pour les utilisateurs standards.

3. Vérification des habilitations

a. Contrôles côté client (JavaScript/UI)

Affichage conditionnel des boutons d'administration uniquement pour les administrateurs.

Redirection des utilisateurs non autorisés si tentative d'accès direct via URL.

b. Contrôles côté serveur (PHP)

Vérification systématique du rôle de l'utilisateur en session avant traitement :

```
php
CopierModifier
if ($_SESSION['role'] !== 'admin') {
    header('Location: index.php');
    exit;
}
```

c. Tests de sécurité

Tentatives d'accès à une page admin avec un compte standard → redirection réussie.

Modification/suppression d'un article sans droits admin → refus de la requête.

Ajout de logs pour les tentatives non autorisées.

4. Gestion et mise à jour des rôles

Les rôles peuvent être modifiés uniquement via l'interface d'administration.

L'administrateur peut promouvoir ou rétrograder un utilisateur via le panneau admin sécurisé.

5. Bonnes pratiques

Les mots de passe sont stockés hashés (ex. : `password_hash()`).

Les sessions sont sécurisées par des cookies HttpOnly.

Le formulaire de connexion est protégé contre les injections SQL (requêtes préparées).

Possibilité d'ajouter un CAPTCHA en cas de suspicion de tentative automatique.